

NEXOVA TECHNOLOGIES PVT. LTD.

Data Protection & Privacy Policy

Version 2.1 | Effective Date: March 1, 2025

Islamabad · Dubai · London

Revision History

Version	Date	Author	Change Summary
1.0	Jan 15, 2024	Ayesha Naqvi, Legal Counsel	Initial release
2.0	Sep 1, 2024	Ayesha Naqvi, Legal Counsel	Added UAE PDPL coverage; updated retention schedule
2.1	Mar 1, 2025	Ayesha Naqvi / Nadia Hussain	Pakistan PDPA 2023 alignment; DPO contact added; biometrics clause

1. Introduction & Scope

Nexova Technologies Pvt. Ltd. (“Nexova,” “we,” “our,” or “the Company”) is committed to protecting the privacy and security of personal data processed across its operations in Islamabad, Dubai, and London. This policy establishes the framework governing how personal data is collected, used, stored, shared, and deleted.

1.1 Who This Policy Applies To

This policy applies to:

- All employees, permanent and part-time, across all Nexova offices
- Contractors, consultants, and temporary workers engaged by Nexova
- Vendors and third-party service providers who process personal data on behalf of Nexova
- Members of the public and prospective clients whose data Nexova holds

1.2 Regulatory Framework

Nexova processes data subject to three overlapping frameworks, applied based on the data subject's location and the applicable office:

- General Data Protection Regulation (GDPR) — EU/UK customer and prospect data processed via the London office
- Pakistan Personal Data Protection Act (PDPA) 2023 — all data subjects in Pakistan, Islamabad HQ operations
- UAE Personal Data Protection Law (Federal Decree-Law No. 45 of 2021) — data subjects in the UAE, Dubai office operations

1.3 Data Covered

- Customer data: contact information, usage data, payment records, and support communications
- Employee data: personal identification, payroll records, performance data, and biometric access logs
- Prospect data: lead contact information and marketing engagement records

2. Data We Collect and Why

2.1 Customer Data

Data Type	Purpose	GDPR Lawful Basis
Name, email, phone	Account creation, support	Contractual necessity (Art. 6(1)(b))
Usage & analytics data	Product improvement	Legitimate interests (Art. 6(1)(f))
Payment data	Billing and invoicing	Contractual necessity + Legal obligation (Art. 6(1)(b)(c))
Support tickets	Customer service delivery	Contractual necessity (Art. 6(1)(b))

2.2 Employee Data

Data Type	Purpose	GDPR Lawful Basis
Personal identification (CNIC, passport)	Employment verification	Legal obligation (Art. 6(1)(c))
Payroll & bank details	Salary processing	Contractual necessity (Art. 6(1)(b))
Performance records	HR management	Legitimate interests (Art. 6(1)(f))
Biometric / access card logs	Office security	Legitimate interests — security (Art. 6(1)(f))

3. Data Retention Schedule

Personal data is retained only for as long as necessary for its stated purpose or as required by law. The table below documents our minimum retention standards. All deletions must be logged in the Data Asset Register maintained by the DPO.

Data Type	Retention Period	Legal Basis	Deletion Method
Payroll & salary records	7 years	PDPA 2023 / Tax law obligation	Secure shred + encrypted wipe
Employee personal info (HR file)	Duration of employment + 5 years	Contractual necessity	Encrypted wipe + physical shred
Performance reviews	5 years post-employment	Legitimate interests	Encrypted wipe
Customer contact data (CRM)	Duration of contract + 3 years	Contractual / Consent	Anonymization then deletion
Customer payment records	7 years	Legal obligation (tax / AML)	Secure encrypted wipe
Support tickets & logs	3 years	Legitimate interests	Automated purge pipeline
Website usage / analytics data	13 months	Consent (cookie policy)	Auto-expiry; anonymized
CCTV footage (all offices)	30 days	Legitimate interests / Security	Auto-overwrite on DVR system

Access card / biometric logs	90 days	Security / Contractual	Encrypted wipe
Job applicant data (unsuccessful)	6 months post-decision	Consent	Encrypted wipe
Signed NDAs & legal contracts	Term + 7 years	Legal obligation	Secure shred + encrypted archive
Marketing consent records	Until consent withdrawn + 2 years	Consent	Anonymization then deletion

Retention periods are reviewed annually by the DPO in consultation with Legal Counsel (Ayesha Naqvi, a.naqvi@nexova.io) and the relevant department head.

4. Data Subject Rights

Data subjects whose information Nexova holds have the following rights, exercisable by submitting a request to privacy@nexova.io. Nexova will verify the identity of the requestor before processing any request.

4.1 Right to Access

Data subjects may request a copy of the personal data Nexova holds about them. Nexova will respond within 30 calendar days of receiving a verified request. Where the request is complex or numerous, this period may be extended by a further 60 days with written notice.

4.2 Right to Rectification

Inaccurate or incomplete personal data will be corrected promptly upon a verified request. Employees may also update personal information directly through their HR file via Sana Mirza (s.mirza@nexova.io).

4.3 Right to Erasure (Right to Be Forgotten)

Data subjects may request deletion of their personal data. Exceptions apply where retention is required by law (e.g., payroll records under Pakistani tax law), necessary for legal claims, or where legitimate interests override. Erasure requests are evaluated within 30 days.

4.4 Right to Data Portability

Where processing is based on consent or contract, and carried out by automated means, data subjects may request their data in a structured, machine-readable format (JSON or CSV). Requests fulfilled within 30 days.

4.5 Right to Object

Data subjects may object to processing based on legitimate interests or for direct marketing purposes. Objections to direct marketing will be honoured immediately. Other objections will be assessed within 30 days.

4.6 How to Submit a Request

- Email: privacy@nexova.io (subject line: "Data Subject Request — [Right Type]")
- Identity verification required: government-issued ID or employee ID for staff requests
- Response SLA: 30 calendar days from verification; extensions communicated in writing
- No fee for standard requests; reasonable administrative fee may apply for manifestly unfounded or excessive requests

5. Data Security Measures

5.1 Technical Controls

- Encryption at rest: AES-256 for all databases and file storage systems
- Encryption in transit: TLS 1.3 enforced for all data transmitted over public networks
- Multi-factor authentication (MFA): mandatory for all internal systems, VPN, and cloud platforms
- Access logging: all access to personal data systems is logged and retained for 90 days
- Regular penetration testing: minimum annually; findings tracked in the IT security register

5.2 Organizational Controls

- Clean Desk Policy: all documents containing personal data must be secured or shredded when unattended
- Access Control Matrix: role-based access reviewed quarterly by Hamza Tariq (IT Support Lead, h.tariq@nexova.io)
- Annual Security Awareness Training: mandatory for all employees; completion tracked by HR and IT
- Confidentiality obligations: all employees sign an NDA with 3-year post-employment survival (aligned with Document 4 NDA terms)

5.3 Vendor Assessment

All vendors and third-party processors who handle Nexova personal data must:

- Execute a Data Processing Agreement (DPA) prior to data access
- Complete Nexova's vendor security questionnaire annually
- Notify Nexova of any sub-processors and obtain prior written approval
- Adhere to standards equivalent to or exceeding those in this policy

Vendor DPA management is overseen by Ayesha Naqvi (a.naqvi@nexova.io).

6. Data Breach Response

6.1 Definition

A personal data breach is any accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data. This includes both technical incidents and human error.

6.2 Internal Reporting

Any employee who discovers or suspects a data breach must report it to the Data Protection Officer within 2 hours of discovery. Initial reports may be verbal, followed by written confirmation via dpo@nexova.io.

6.3 Regulatory Reporting

- GDPR (London office): notification to the UK ICO or relevant EU supervisory authority within 72 hours of becoming aware of the breach, where required
- Pakistan PDPA 2023: notification to the Personal Data Protection Authority in accordance with applicable timelines
- UAE PDPL: notification to the UAE Data Office as required by Federal Decree-Law No. 45 of 2021

6.4 Customer Notification

Where a breach is assessed as high risk to data subjects' rights and freedoms, affected customers will be notified within 5 business days of the determination. Notification will include the nature of the breach, categories of data involved, likely consequences, and measures taken.

6.5 Breach Log

All breaches, including near-misses, must be recorded in the Nexova Breach Log maintained by the DPO. The log captures: date of discovery, nature of breach, data affected, root cause, remediation steps, and regulatory notifications made.

7. International Data Transfers

7.1 EU/UK Data Transfers (London Office)

Transfers of EU or UK personal data to Nexova's Islamabad HQ are governed by Standard Contractual Clauses (SCCs) approved by the European Commission. Nexova relies on the International Data Transfer Agreement (IDTA) for UK transfers.

7.2 Adequacy Decisions

Where the European Commission or UK ICO has issued an adequacy decision for a destination country, Nexova may rely on that decision in lieu of SCCs. Nexova monitors the status of adequacy decisions for countries in which it operates.

7.3 Data Residency Commitments

Region	Data Residency Commitment	Transfer Mechanism
EU / UK customers	Primary processing in London; backup in EU-based cloud region	SCCs / IDTA
UAE customers	Processing within UAE or GCC-compliant region where feasible	UAE PDPL Chapter 9
Pakistan (HQ)	Primary processing in Islamabad; PDPA 2023 compliance	PDPA 2023 provisions

8. Data Protection Officer (DPO)

8.1 DPO Details

Name	Zara Khalid
Title	Data Protection Officer
Email	dpo@nexova.io
Reports To	Zain ul Abideen, CEO

8.2 DPO Responsibilities

- Monitoring compliance with GDPR, PDPA 2023, and UAE PDPL on an ongoing basis
- Acting as point of contact for data subjects and regulatory authorities
- Conducting and overseeing Data Protection Impact Assessments (DPIAs) for high-risk processing activities
- Maintaining the Data Asset Register and Breach Log
- Delivering or overseeing annual mandatory data protection training
- Advising on vendor DPAs and sub-processor agreements in coordination with Ayesha Naqvi
- Escalating material compliance issues to the CEO (Zain ul Abideen)

Employees with data protection questions or concerns may contact the DPO directly at dpo@nexova.io. Ethics-related concerns may be escalated to ethics@nexovatech.com.

This policy is reviewed annually or upon material changes to applicable law. Next scheduled review: March 1, 2026.

Approved by: Zain ul Abideen, CEO, Nexova Technologies Pvt. Ltd.